Ciberseguridad Aplicada

› Ofensiva controlada, defensa, forense y marco legal sobre un laboratorio propio

Prof. César Rodríguez | ELECTRONICA | 1 de noviembre de 2026

1 Identificación

Código	CYBERSEGURIDAD
Duración	10 semanas
Grupos	4 grupos de trabajo
Modalidad	Trabajo por grupos desde sus propios equipos y conexión, con laboratorio Docker local y repositorio GitHub por grupo revisado semanalmente; sin proyecto integrador
Entrega	GitHub por grupo, revisado al finalizar cada semana
Dedicación	4 horas de laboratorio + 2 horas de estudio independiente
Versión	1

2 Objetivo general

Formar criterio técnico y legal para auditar, defender, investigar y documentar incidentes de seguridad sobre sistemas propios o expresamente autorizados, cubriendo el ciclo completo: reconocimiento, explotación controlada, hardening, forense y respuesta, con evidencia reproducible y respeto estricto del alcance.

3 Resultados de aprendizaje

1. RA1: Explicar activos, amenazas y vulnerabilidades con marcos reconocidos (CIA, STRIDE, MITRE ATT&CK) y priorizar riesgos con evidencia.
2. RA2: Aplicar criptografía simétrica, asimétrica, funciones hash y KDF, y diagnosticar una configuración TLS insegura.
3. RA3: Interpretar el marco legal y normativo aplicable antes de tocar un sistema, y redactar un alcance de auditoría autorizado.

4. RA4: Ejecutar reconocimiento, escaneo y explotación controlada contra objetivos del laboratorio, documentando cada paso.
5. RA5: Endurecer sistemas y redes, y demostrar la mitigación repitiendo el ataque original.
6. RA6: Adquirir y preservar evidencia digital con cadena de custodia e integridad verificable.
7. RA7: Reconstruir un incidente a partir de artefactos y producir un informe técnico y otro ejecutivo.

4 Estructura por fases

Fase 1 — Fundamentos, criptografía y marco legal

Semanas 1 a 3. Vocabulario común, criptografía aplicada y límites legales antes de tocar un sistema.

Fase 2 — Ofensiva controlada

Semanas 4 a 5. Reconocimiento, escaneo y explotación documentada contra objetivos propios.

Fase 3 — Defensa y hardening

Semanas 6 a 7. Endurecer sistemas, redes y aplicaciones, y demostrar la mitigación.

Fase 4 — Forense y respuesta a incidentes

Semanas 8 a 9. Adquirir evidencia, reconstruir lo ocurrido y responder con método.

Fase 5 — Cierre

Semana 10. Evaluación final práctica de alcance cerrado, con informe y defensa.

5 Sistema de evaluación

Concepto	Peso (%)
Prácticas de laboratorio (semanas 1-9)	35,0
Controles de fase (semanas 3, 5 y 7)	15,0
Informes técnicos (semanas 5, 7 y 9)	15,0
Evaluación final práctica (semana 10)	25,0
Ética, autorizaciones y uso responsable	10,0
Total	**100,0**

Recuerda

La escala de calificación es de 10 puntos y la nota mínima aprobatoria es 5. La nota del curso se calcula ponderando los conceptos de la tabla; no se promedian notas de distinta escala.

6 Entrega y revisión semanal

- Plataforma: GitHub.
- Modalidad: Un repositorio privado por grupo, con el docente como colaborador de lectura.
- Cadencia: El docente revisa el repositorio al finalizar cada semana de práctica.
- Corte: Domingo 23:59 de la semana correspondiente; lo posterior no se corrige.

Estructura del repositorio

- README.md con integrantes, roles y tabla de semanas entregadas.
- semana_NN/informe.md o informe.pdf con el entregable de esa práctica.
- semana_NN/scripts/ con el código, con type hints y docstrings.
- semana_NN/evidencia/ con salidas, capturas y hashes anonimizados.
- semana_NN/README.md con el resumen de lo hecho y lo que no se pudo verificar.

Reglas de entrega

- Nada de secretos, tokens ni contraseñas en el repositorio; las claves van en .env ignorado.
- Nada de imágenes de disco, muestras de malware ni binarios: solo hashes y enlaces.
- Evidencia anonimizada: sin datos personales de terceros ni credenciales reales.
- Un commit por entrega con mensaje "semana NN: <entregable>".
- La práctica cuenta como entregada solo si está en el repositorio antes del corte.

Recuerda

La entrega se considera válida solo cuando está en el repositorio del grupo antes del corte. Un enlace, una captura suelta o un archivo enviado por mensajería no sustituyen el repositorio.

7 Laboratorio

Contenedor	Imagen	Puerto	Propósito
objetivo-web	`vulnerables/web-dvwa:latest`	8081	Inyección SQL, XSS, LFI y control de acceso (semanas 5 y 7)
objetivo-juice	`bkimminich/juice-shop:latest`	3000	Retos guiados de OWASP Top 10 (semanas 5 y 7)
objetivo-linux	`ubuntu:24.04`	2222	Hardening, SSH y artefactos forenses (semanas 6, 8 y 9)

Requiere ~2 GB de RAM libre y ~5 GB de disco; DVWA y Juice Shop juntos consumen menos de 700 MB.

El docker-compose de esta carpeta es opcional. Cada grupo puede usar su propio entorno en su PC siempre que respete el alcance autorizado.

- {'Cada grupo trabaja desde su propio equipo y red': 'no hay red compartida del curso.'}
- El laboratorio corre en localhost y nunca se expone a Internet.
- Solo se atacan contenedores del laboratorio o sistemas con autorización escrita y firmada.
- {'Las muestras de malware no se ejecutan': 'el análisis es estático y sobre copias inertes.'}
- La evidencia se anonimiza antes de entregarse; los datos personales no salen del laboratorio.
- Se prohíbe el uso de estas técnicas contra la infraestructura de la universidad o de terceros.

8 ⚖ Políticas de uso

- Cada grupo mantiene su propio repositorio GitHub y lo entrega actualizado antes del corte semanal; el docente revisa ese repositorio.
- {'El trabajo se hace desde el equipo y la conexión de cada grupo': 'solo objetivos propios, el laboratorio provisto o sistemas con autorización escrita; nunca infraestructura de la universidad ni de terceros.'}
- Solo se atacan objetivos propios o con autorización escrita y firmada.
- El laboratorio es local y nunca se expone a Internet.
- Las muestras de malware no se ejecutan y se manejan como copias inertes.
- La evidencia se anonimiza antes de entregarse.
- El uso indebido de las técnicas del curso tiene consecuencias académicas y legales.
- El código entregado usa type hints, docstrings estilo Google y manejo explícito de errores.

9 Bibliografía

- Stuttard, D. y Pinto, M.. The Web Application Hacker’s Handbook. Referencia para reconocimiento y explotación de aplicaciones web.
- OWASP Foundation. OWASP Top 10 2021. Categorías de riesgo en aplicaciones web.
- OWASP Foundation. Web Security Testing Guide y ASVS. Metodología de pruebas y estándar de verificación.
- NIST. CSF 2.0 y SP 800-61r2. Marco de ciberseguridad y guía de respuesta a incidentes.
- ISO IEC. ISO IEC 27001 2022. Sistema de gestión de seguridad de la información.
- MITRE. ATT&CK Enterprise Matrix. Tácticas y técnicas de adversario para nombrar lo observado.
- Asamblea Nacional de Venezuela. Ley Especial contra los Delitos Informáticos. Tipificación de delitos informáticos aplicable al curso.
- Sikorski, M. y Honig, A.. Practical Malware Analysis. Referencia opcional para el triage estático de la semana 9.